PRODUCT SPECIFICATION AND BUILDER GUIDE

BioPrep

NEET (UG) Biology test preparation: timed mock tests, and solutions that make students think before they are told.

VERSION	1.0 (built state, 23 October 2026)
SOURCE	GitHub samkangom/bioprep, branch claude/quirky-franklin-3k5blt, commit 3645a1e
AUDIENCE	Product owner, builders (frontend, backend, database), testers, reviewers
STATUS	All features below are built and tested locally. Nothing has been run against real Supabase, Razorpay, Anthropic, Vercel or Render accounts yet.

How to read this document

Part 1 says what the product is, who uses it, and the rules that do not change. **Part 2** describes every feature as user stories, each with acceptance criteria (the checks that prove it works) and a note for builders on where it lives and what to be careful about. **Part 3** is the builder guide: architecture, data, security, API, configuration, testing and deployment. **Part 4** lists decisions, limits and what is next.

Story IDs (for example `PAY-3`) are stable. Use them in tickets and test names.

Part 1. Product

1.1 What BioPrep is

BioPrep helps Indian students preparing for NEET (UG) practise Biology. A student takes a timed mock test that is scored like the real exam (+4 for a correct answer, -1 for a wrong one, 0 for a skipped one). Afterwards the student opens a **solution**. Instead of showing the answer straight away, a tutor asks two or three short guiding questions so the student reasons it out first. Only when the student has finished, or the 2:00 timer ends, or the student asks, do they see the answer, the written explanation and a video.

The business model is simple: a free plan gives **2 full explanations in total**. After that, **Rs 100 per test** unlocks every solution and video in that test, forever.

1.2 Who uses it

PERSON	GOAL	WHAT THEY CAN DO
Student (many are under 18)	Practise, find weak chapters, understand mistakes.	Sign in with a phone number, take tests, read results, open solutions, pay to unlock a test, see payment history, download or delete their data.
Parent or guardian (indirect)	Agree to a minor using the service.	Gives consent during the student's sign-up (name, mobile, relationship, a tick). They do not have their own login.
Teacher	Build the question bank and tests.	Everything content-related: questions, diagrams, videos, tests, content analytics. Cannot see money or the user list.
Admin	Run the business.	Everything a teacher can, plus users and roles, payments, refund flags, revenue, manual unlocks.
Builder	Extend and operate the system.	Uses this document, the repository and the test suites.

1.3 Rules that must not change without the owner's approval

RULE	VALUE	WHERE IT IS DEFINED
Subjects live	Biology (Botany and Zoology). Physics and Chemistry show as Coming soon.	src/views/Home.jsx

RULE	VALUE	WHERE IT IS DEFINED
Marking	+4 correct, -1 wrong, 0 skipped. Fixed for every question.	shared/rules.js and SQL submit_attempt
Free plan	2 full explanations in total (tutor session plus video), across all tests.	shared/rules.js, SQL free_explanation_limit()
Price	Rs 100 per test, one time, unlocks all solutions and videos in that test.	tests.price_inr (default 100)
Tutor timer	2:00 per question. Video unlocks after the guided questions finish, the timer ends, or the student taps Show me the answer. Paid students also get Skip to video.	shared/rules.js, server/tutor.js
Test	Timed, question palette, mark for review, auto-submit at 00:00.	src/views/TestFlow.jsx
Roles	student, teacher, admin. Enforced on the server, never only in the screen.	SQL profiles.role and RLS

Part 2. Features as user stories

Each story follows: *As a [person], I want [action], so that [benefit]*. Acceptance criteria are written so a tester can check each line. "Builders" notes say where the work lives and what is easy to get wrong.

2.1 Account and onboarding

AUTH-1 Sign in with my phone number

As a *student,* **I want** *to sign in with my mobile number and a one-time code,* **so that** *I do not need to remember a password.*

ACCEPTANCE CRITERIA

- The phone field accepts a 10-digit Indian mobile number starting 6 to 9; anything else shows a clear error.
- A 6-digit code is sent by SMS. A wrong code shows an error and does not sign me in.
- I can resend the code after 30 seconds; the button shows the countdown.
- After signing in, reloading the page keeps me signed in. The sign-out button signs me out.
- A returning user goes straight to the home screen; a new user goes to AUTH-2.

Builders: Supabase phone OTP (src/backend/remote.js: sendOtp, verifyOtp). SMS delivery needs a provider configured in Supabase; for India that means DLT-registered templates. Offline demo mode accepts any 4 digits.

AUTH-2 Introduce myself the first time

As a *new student,* **I want** *to give my name, exam year and date of birth, and accept the privacy policy,* **so that** *my account is set up properly.*

ACCEPTANCE CRITERIA

- I enter my name, choose NEET year 2027, 2028 or 2029, and enter my date of birth.
- I must tick that I have read the privacy policy (it opens in a new tab and keeps my form).
- Only my birth year is stored, never the full date of birth.
- The form cannot be submitted without all of the above.

Builders: Server function complete_signup computes age from the date it receives and discards the date. Do not add a column for the full date.

AUTH-3 Parent or guardian consent when I am under 18

As a *student under 18,* **I want** *my parent or guardian to agree before I start,* **so that** *the service is used with their knowledge.*

ACCEPTANCE CRITERIA

- If my age is 13 to 17, a Parent or guardian consent section appears: relationship (mother, father, legal guardian), their full name, their 10-digit mobile number, and a consent tick.
- If I am under 13, sign-up is refused with a clear message.
- I cannot continue until every consent field is complete.
- If I am 18 or older, none of this appears.
- The consent record (name, number, relationship, policy version, time) is saved and deleted if my account is deleted.

Builders: The guardian is NOT verified (no OTP to their phone). It is a recorded declaration. Whether this meets the DPDP Act needs legal review. Minimum age 13 is MIN_AGE in src/privacy.js and in the SQL; change both together.

AUTH-4 Choose language and light or dark

As a *student,* **I want** *to switch between English and Hindi and between light and dark themes,* **so that** *the app is comfortable to read.*

ACCEPTANCE CRITERIA

- A language selector in the header offers English and Hindi. Meiteilon is listed as soon and cannot be selected yet.
- My choice is remembered on this device.
- The sign-in, header, footer and home screens change language; other screens are still English (see 4.2).
- The dark mode button works and the app follows my phone's setting by default.

Builders: src/i18n holds English (source of truth), Hindi (first draft, needs native review) and an empty Meiteilon file. New student-facing strings go through t(key) and are added to en.js first.

2.2 Tests

TEST-1 See the tests I can take

As a *student,* **I want** *to see Biology tests with their size, duration and my last score,* **so that** *I can choose what to practise.*

ACCEPTANCE CRITERIA

- The home screen shows Biology as live, with the number of Botany and Zoology questions, and Physics and Chemistry as Coming soon.
- Each published test shows its type, number of questions, duration in minutes, my last score if I have one, and either an unlocked badge or its unlock price.
- Buttons: Start test or Retake test, View result (if I have attempted it), Unlock (if not unlocked).
- A banner states how many free explanations I have left, or that they are used up.

TEST-2 Read the instructions before I start

As a *student,* **I want** *to see the rules of the test first,* **so that** *nothing surprises me.*

ACCEPTANCE CRITERIA

- The page shows question count, duration and marking (+4 / -1).
- It explains the timer, mark for review, and auto-submit.
- Start test begins the attempt.

TEST-3 Take a timed test

As a *student,* **I want** *to answer questions one at a time with a timer and a question palette,* **so that** *it feels like the real exam.*

ACCEPTANCE CRITERIA

- One question is shown at a time with four options. Option labels follow the question's chosen style (A B C D, 1 2 3 4, i ii iii iv, and so on).
- A question may include a diagram.
- Selecting an option highlights it; Clear response removes it; Save and next, Previous and the palette move between questions.
- Mark for review flags a question. Palette colours and shapes show answered, not answered, marked, current and not visited, with a legend.
- A countdown timer is always visible and changes style when 10 minutes and 2 minutes remain (colour plus the timer itself).
- Time spent on each question is recorded.

Builders: The attempt is created on the server when the test page opens (start_attempt) so the server clock starts with the student's. Answers live only in the browser until submission. A page refresh mid-test loses the answers (see 4.2).

TEST-4 Submit my test

As a *student,* **I want** *to submit by hand or have it submit itself at 00:00,* **so that** *my score is recorded fairly.*

ACCEPTANCE CRITERIA

- Pressing Submit shows a summary (answered, not answered, marked, time left) and asks me to confirm.
- At 00:00 the test submits itself.
- If the network fails, my answers stay on screen with a Try again button; nothing is lost.
- The score is calculated on the server, not in the browser. The browser never receives the correct answers.
- A submission that arrives up to 5 minutes after the time limit is accepted (slow networks); later ones are refused with a clear message.

Builders: SQL function submit_attempt does the scoring and is idempotent: submitting twice returns the same result.

2.3 Results

RES-1 See how I did

As a *student,* **I want** *my score, accuracy, number attempted and time used,* **so that** *I know where I stand.*

ACCEPTANCE CRITERIA

- Four tiles: score out of the maximum, accuracy on attempted questions, attempted out of total, and time used.

RES-2 See where I am strong and weak

As a *student,* **I want** *breakdowns by outcome, subject, chapter and time,* **so that** *I know what to revise.*

ACCEPTANCE CRITERIA

- A donut shows correct, incorrect and skipped, with numbers and icons, not colour alone.
- Bars show results for Botany versus Zoology and by chapter.
- A time-per-question strip highlights questions that took more than 1.5 times the average.

RES-3 Review each question

As a *student,* **I want** *a table of every question with my answer and whether it was right,* **so that** *I can go back to the ones I missed.*

ACCEPTANCE CRITERIA

- Each row shows the question, my answer, and Correct, Incorrect or Skipped with an icon and text.
- The correct answer is not shown in the table until I have opened that question's explanation; the cell says it is shown with the explanation.
- Each row has an Explain button. Retake and Back to tests are available.

Builders: Deliberate decision: showing the answer here would bypass the tutor. Students still see which of their picks were right because that is the score.

2.4 Solutions: the Socratic tutor

SOL-1 Open a solution

As a *student,* **I want** *to open the explanation for a question from my result,* **so that** *I learn from it.*

ACCEPTANCE CRITERIA

- The server checks my entitlement first (see PAY-1 to PAY-4). If allowed, the tutor opens; if not, I see the locked card (PAY-2).
- I can only open explanations for questions that were in a test I have submitted.
- Prev and Next move between the questions of the test.

Builders: One gate decides this: SQL private.open_explanation, called only by the API (POST /api/explain/open). Staff opening a question for preview never use up a free slot.

SOL-2 Be guided to the answer

As a *student,* **I want** *a tutor that asks me two or three short questions,* **so that** *I work out the idea myself.*

ACCEPTANCE CRITERIA

- The tutor greets me and asks the first guiding question. A stage tracker (Recall, Reason, Apply) shows progress.
- I can tap one of the answer buttons or type my own answer (up to 500 characters).
- After each answer a chip shows On track, Partly there, Let us rethink or Hint given (icon plus text), and a You have worked out list builds up.
- The tutor never states the correct option before the session ends. If its reply would give the answer away, the server replaces it with the built-in guide's reply.
- After at most 5 of my messages the session ends.

Builders: The tutor is Claude when an API key is configured; otherwise, or if Claude fails or the daily limit is reached, a scripted keyword guide answers. The screen shows which one is helping. Prompts are built on the server from the database; the browser sends only {questionId, messages, kind, hintLevel}.

SOL-3 Ask for a hint or say I am not sure

As a *student,* **I want** *up to 3 hints, each stronger than the last,* **so that** *I get unstuck without being told the answer.*

ACCEPTANCE CRITERIA

- Give me a hint gives hint 1 (rephrase), then 2 (a concrete clue), then 3 (nearly gives it away). The button shows 1/3, 2/3, 3/3 and then stops.
- I am not sure gives an easier version of the question and does not use a hint.

SOL-4 Have a fair time limit

As a *student,* **I want** *a 2:00 timer per question,* **so that** *I do not stay stuck forever.*

ACCEPTANCE CRITERIA

- A 2:00 timer counts down. It pauses while the tutor is thinking.
- At 00:00 the explanation opens by itself.
- The timer is also kept on the server: the browser cannot reveal the answer early by claiming time is up.

Builders: Server tracks started_at and paused_ms (time waiting on the model). A timeout reveal earlier than 117 seconds (120 minus a 3 second grace) is refused.

SOL-5 See the full explanation when I am done

As a *student,* **I want** *the correct answer, a written explanation, why each wrong option is wrong, and a short summary,* **so that** *I understand and remember it.*

ACCEPTANCE CRITERIA

- The explanation opens when the guided questions end, the timer ends, or I tap Show me the answer.
- It shows: Answer with its label, the explanation, why each other option is wrong, Key idea, Common mistake, and the NCERT reference.
- On the question card the correct option is now marked Correct with an icon, and my wrong pick is marked Your answer.
- If I took part, a short Your thinking note shows what I did well, what to revisit and one exam tip.

Builders: Served by GET /api/explain/:questionId, which returns 403 until the server has marked the session finished. Nothing else carries these fields.

SOL-6 Watch the video explanation

As a *student,* **I want** *a short video for each question,* **so that** *I can see the concept explained.*

ACCEPTANCE CRITERIA

- The video panel is locked (with a message) until the tutor session ends.
- Paid students can tap Skip to video to watch before the session ends.
- Controls: play and pause, speed 1x, 1.5x, 2x, captions text, full screen.
- If a question has no video yet, the panel says so.
- If the video link expires during playback, the player gets a fresh link and carries on.

Builders: Videos are in a private bucket. POST /api/video-url signs a 10-minute URL only for an allowed session. Never expose the storage path to students.

SOL-7 Come back to an explanation I already earned

As a *student,* **I want** *to reopen a finished explanation without redoing it,* **so that** *I can revise quickly.*

ACCEPTANCE CRITERIA

- Reopening a question I already finished shows the explanation directly, with no new tutor chat.
- It does not use another free explanation.

SOL-8 Save questions to revise

As a *student,* **I want** *a Save to revision list button after an explanation,* **so that** *I can come back to hard questions.*

ACCEPTANCE CRITERIA

- The button appears after the explanation opens, toggles saved or not, and the Profile screen lists saved questions.

2.5 Free plan, paywall and payments

PAY-1 Use the free plan

As a *student,* **I want** *2 free full explanations,* **so that** *I can try the tutor before paying.*

ACCEPTANCE CRITERIA

- The header and solution screens show Free explanations left: N.
- Opening an explanation for a question uses one free slot. Reopening the same question does not use another.
- The two free slots are shared across all tests, not per test.

PAY-2 See clearly when I need to pay

As a *student,* **I want** *a clear locked screen after my free explanations are used,* **so that** *I know what to do next.*

ACCEPTANCE CRITERIA

- The locked card says my free explanations are used, shows my result for this question (right, wrong or skipped) and an Unlock for Rs 100 button.
- The question and my own answer stay visible.

PAY-3 Pay Rs 100 to unlock a test

As a *student,* **I want** *to pay with UPI or card,* **so that** *I get every solution and video in that test.*

ACCEPTANCE CRITERIA

- Pay opens Razorpay's payment window (UPI and cards).
- After I pay, the screen says Confirming your payment. It changes to Payment successful only when the server has received Razorpay's confirmation, which usually takes seconds.
- If confirmation is slow, I see a message that my test will unlock shortly, a Check again button, and I can close the window safely.
- If the payment fails I see a clear message that I was not charged, and a Try again button.
- After success, the locked question opens straight into the tutor.

Builders: Crucial: the browser's payment success callback never unlocks anything. Only a verified Razorpay webhook (signature checked over the raw body, amount matched to the order, idempotent on event id) inserts an unlock. The price is read from the database, never from the browser.

PAY-4 Keep what I paid for

As a *student,* **I want** *an unlock to cover all questions of that test permanently,* **so that** *I do not pay twice.*

ACCEPTANCE CRITERIA

- An unlock covers every explanation and video in that test only. Other tests still follow the free plan.
- Unlocks survive sign-out and new devices.
- A test I already unlocked cannot be bought again.

PAY-5 See my payments

As a *student,* **I want** *a Payment history screen,* **so that** *I have a record.*

ACCEPTANCE CRITERIA

- It lists date, test, amount, status (Paid, Refunded, Failed, each with icon and text) and Razorpay payment id.
- A paid item under review shows Refund under review.

PAY-6 Get a refund when something went wrong

As a *student,* **I want** *to ask for a refund,* **so that** *I am treated fairly.*

ACCEPTANCE CRITERIA

- The student contacts support (the contact address is configured in the app).
- An admin flags the payment for refund with a note (see ADM-8) and issues the refund in the Razorpay dashboard.
- When Razorpay confirms the refund, the payment shows Refunded and that test locks again automatically.

2.6 Privacy and control of my data

PRIV-1 Read the privacy policy before signing up

As a *visitor,* **I want** *a plain-language policy at a public address,* **so that** *I know what is collected and why.*

ACCEPTANCE CRITERIA

- It opens from the sign-in screen, the footer and the address /#/privacy without signing in.
- It states: what is collected, why, who handles it (Supabase, Anthropic, Razorpay, an SMS provider, hosting), retention periods, the rules for students under 18, and how to use my rights.

Builders: Have a lawyer review the text before launch. Retention numbers are in src/privacy.js and the SQL purge function; keep them equal.

PRIV-2 Download my data

As a *student,* **I want** *a file of everything the service holds about me,* **so that** *I can see and keep it.*

ACCEPTANCE CRITERIA

- Profile, Privacy, Download my data gives a JSON file with my profile, consent record, attempts and answers, unlocks, payments, free explanations used and revision list.

PRIV-3 Delete my account and data

As a *student,* **I want** *to delete everything,* **so that** *I stay in control.*

ACCEPTANCE CRITERIA

- I must type DELETE to confirm; the dialog says it cannot be undone and that paid tests will lock.
- My account, attempts, answers, unlocks, saved questions and consent record are removed.
- Payment records stay for accounting but are no longer linked to me.
- Signing in again with the same number starts a brand-new account.
- The last remaining admin cannot delete their account.

2.7 Teacher and admin tools

AREA	TEACHER	ADMIN
Dashboard, Question bank, Tests, Analytics (content)	Yes	Yes
Payments, refund flags, revenue	No	Yes
Users and plans, role changes, manual unlock	No	Yes
View the student screens (switch in the header)	Yes	Yes

ADM-1 See the state of the business at a glance

As a *admin,* **I want** *a dashboard,* **so that** *I know what exists and what is happening.*

ACCEPTANCE CRITERIA

- Shows counts of tests, questions (and how many are published), submitted attempts and, for admins, students and active unlocks.
- Quick actions: Add question, Build a test, See analytics.

ADM-2 Find questions

As a *teacher,* **I want** *a searchable list of all questions,* **so that** *I can manage the bank.*

ACCEPTANCE CRITERIA

- The list shows question, subject, chapter, difficulty, whether a video is uploaded, and status (draft or published).
- I can filter by subject and status and search the question text.

ADM-3 Create and edit a question

As a *teacher,* **I want** *a form for one question with its explanation, tutor prompts, diagram and video,* **so that** *students get a complete lesson.*

ACCEPTANCE CRITERIA

- Fields: subject (Botany or Zoology), chapter, difficulty, question text, four options with the correct one selected, Option labels style, NCERT reference, written explanation, 2 to 3 guiding questions (with expected keywords and a hint), caption text.
- Option labels can be A B C D, a b c d, 1 2 3 4, i ii iii iv, I II III IV or Hindi letters. The correct answer is always stored by position, so changing the style never breaks scoring.
- Diagram: upload a PNG, JPEG or WebP up to 5 MB. Alt text is required before saving.
- Video: upload an MP4 up to 200 MB with a progress bar and a Cancel button; wrong type or oversize files are rejected before upload; a replaced or cancelled upload is cleaned up.
- Save draft needs only the question, four options and the correct answer. Publish additionally needs an explanation and at least two guiding questions.
- Only published questions can go into a published test.

Builders: Writes go through the SQL function admin_upsert_question (one transaction across questions, question_secrets and socratic_steps). The editor reads secrets via admin_get_question; students can never call it.

ADM-4 Import many questions from a spreadsheet

As a *teacher,* **I want** *to upload a CSV file,* **so that** *I do not type hundreds of questions.*

ACCEPTANCE CRITERIA

- A downloadable template shows the columns: subject, chapter, difficulty, question, optA to optD, correct, ncert, explanation, ask1, keys1, hint1, ask2, keys2, hint2 (optional ask3, keys3, hint3, optstyle).
- After choosing a file I see a preview: total rows, how many are ready, have warnings, or have errors, and each row's problems by line number.
- Rows with errors are skipped. Duplicates (against the bank or inside the file) are errors. Physics or Chemistry rows are errors for now.
- Valid rows are imported as drafts, with a progress bar and a final summary; one failed row does not stop the others.
- Limits: 500 rows and 1 MB per file.

ADM-5 Build and publish a test

As a *teacher,* **I want** *to choose questions, order them, and set duration and price,* **so that** *students can take it.*

ACCEPTANCE CRITERIA

- I name the test, set the duration in minutes and the unlock price, tick published questions, and reorder them.
- A Published switch makes it visible to students. A test cannot be published with no questions or with draft questions.

ADM-6 Learn from real results

As a *teacher,* **I want** *analytics from real attempts,* **so that** *I improve the content.*

ACCEPTANCE CRITERIA

- Average score by test; hardest questions (lowest share correct, shown once a question has at least 3 answers); time per question; and for admins, revenue.
- Every number comes from the database. Empty states say there is no data yet. No sample numbers are shown in the live app.

ADM-7 Manage users

As a *admin,* **I want** *a list of users with roles and a way to help them,* **so that** *I can run support.*

ACCEPTANCE CRITERIA

- The list shows name, masked phone number (like 9198xxxx0088), role, unlocked tests and attempts.
- I can change someone's role (not my own). Manual unlock gives a student a test without payment, for support cases.

ADM-8 Handle refunds

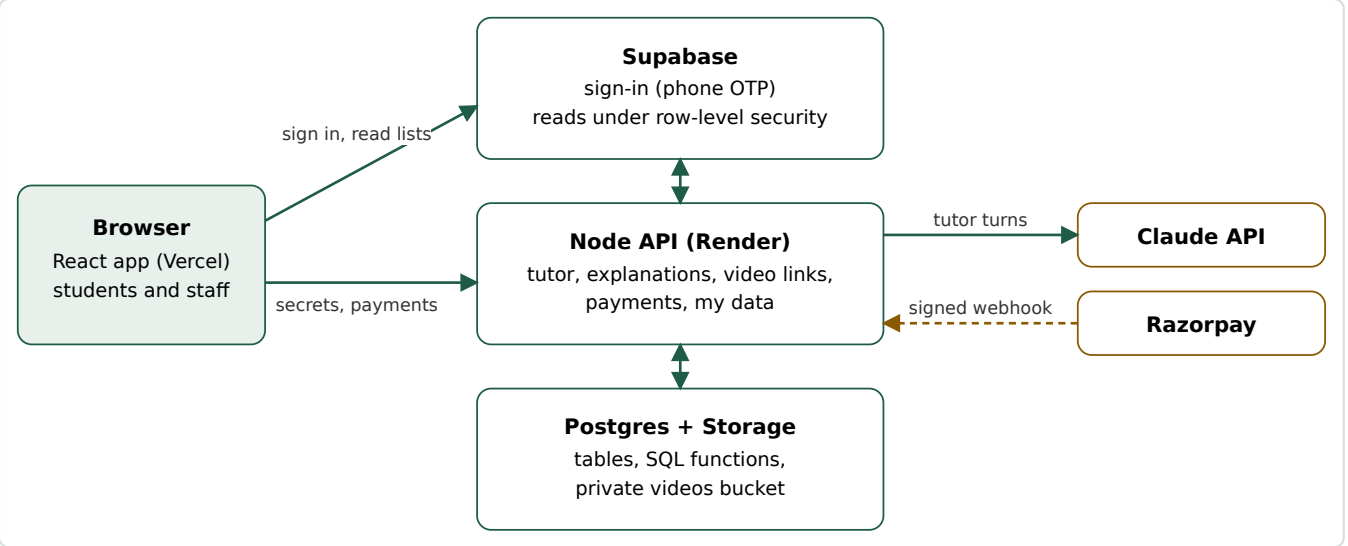
As a *admin,* **I want** *to see all payments and flag one for refund,* **so that** *refunds are tracked.*

ACCEPTANCE CRITERIA

- The Payments tab lists date, student, test, amount, method, status and refund flag with note.
- Flag for refund records a reason and who flagged it; Clear flag removes it. Flagging does not move money or lock the test.
- When Razorpay later confirms the refund, the status becomes Refunded and the unlock is revoked.

Part 3. Builder guide

3.1 Architecture in one picture



Solid arrows: requests. Dashed: Razorpay calls the API's webhook after a payment.

The idea in one sentence: **the browser may read what a student is allowed to see; anything secret or privileged goes through the API or a SQL function that checks who is asking.**

3.2 Repository map

PATH	WHAT IS THERE
src/	React 18 + Vite app. views/ = screens; store.jsx = app state with the same action names throughout; backend/ = mock.js (offline demo, localStorage) and remote.js (Supabase); api.js, tutorDriver.js = talk to the API; i18n/ = languages; csv.js, media.js, checkout.js = helpers.
shared/	Code used by browser, API and tests: rules.js (all product constants), tutor-core.js (prompts, validation, answer-leak guard, scripted tutor, hint ladder), labels.js (option labels).
server/	Node API (Express): app.js routes, tutor.js, video.js, payments.js, me.js, claude.js, razorpay.js, auth.js, storage.js, db.js. Everything external is injected, so tests swap in fakes.
supabase/	migrations/ (the database, in order), setup-all.sql (all migrations in one file for pasting into the Supabase SQL editor), seed.sql (generated from src/data.js by npm run gen:seed), config.toml.
dev/	Local stack for development and tests only: in-process Postgres (PGlite), a small stand-in for Supabase sign-in, data and storage, and the API. Never deploy it.
tests/, server/*.test.js, e2e/	Unit and database tests (vitest) and browser tests (Playwright).
docs/LAUNCH.md	Go-live checklist. CLAUDE.md holds the product rules, status and conventions.

3.3 Data model

TABLE	PURPOSE	WHO CAN READ OR WRITE
profiles	One per user: role, name, phone, exam year, birth year, is_minor, language.	Own row; admins read all. Students may edit only name, exam year, language.
questions	The part safe to show during a test: subject, chapter, text, four options, option style, diagram path and alt text, status.	Students read published; staff read and write all.
question_secrets	Correct answer, explanation, why-wrong, recap, NCERT, caption, video path.	Staff only. Students never.
socratic_steps	2 to 3 guiding questions with keywords, hints and tap choices.	Staff only.
tests, test_questions	A test and its ordered questions, duration, price, published flag.	Students read published; staff write.
attempts, attempt_answers	Each attempt and, per question, the chosen option, correct or not, and seconds.	Own rows; created and scored only by SQL functions.
free_explanation_uses	Which questions used a free slot (limit 2 per student).	Read own; inserts capped by a trigger.
unlocks	A student's paid or manual unlock of a test (with revoked_at).	Read own; written only by the payment webhook or admin function.
tutor_sessions	Per student and question: access type, status, timer data, counters. No chat text.	Read own; written only by the API.
ai_usage	Token counts and timings per tutor call. No prompts or replies.	Admin read; API write.
payments, payment_events	Razorpay orders, status, refund flag; processed webhook event ids.	Student reads own; admin reads all; API writes.
parental_consents	Guardian name, mobile, relationship, policy version, time.	Read own; written at sign-up by a SQL function.
revision_items	Questions a student saved.	Own rows.

Storage buckets: **videos** (private, MP4 only, 200 MB, staff-only access) and **diagrams** (public read, images up to 5 MB, staff write, random file names).

3.4 Security model (read this before changing anything)

- **Never trust the browser.** Scoring, entitlement, the tutor timer, prices and unlocks are all decided on the server or in SQL.
- **Secrets live in tables students cannot read.** Row-level security cannot hide single columns, which is why correct answers, explanations and tutor prompts are in separate tables (question_secrets, socratic_steps).
- **One entitlement gate.** private.open_explanation decides staff preview, paid unlock, already-spent free slot, new free slot or paywall, using a lock so two parallel requests cannot exceed the free limit. Clients have no write access to unlocks, free uses, sessions or usage.

- **Payments unlock only from the webhook.** HMAC-SHA256 over the raw request body, amount and currency matched to our own order, idempotent on Razorpay's event id. The browser success callback is ignored.
- **Helpers are private.** Internal functions are in a private schema that the Supabase API does not expose, and execute permission is revoked from signed-in users.
- **Keys.** Anything with VITE_ in its name is public. The service_role key, database URL, Anthropic key and Razorpay secrets exist only on the API host.
- **Minimal data.** Chat text is never stored. Birth year only. Phone numbers are masked in admin screens. Retention job purges old rows.
- **Tutor answer-leak guard.** Before showing a Claude reply, the server blocks explicit answer statements ("the answer is", option labels) and long verbatim runs from the explanation, and falls back to the scripted tutor.

3.5 Key flows

A. Take and score a test

1. Student opens the test: browser calls start_attempt, server creates an attempt row and its clock.
2. Student answers in the browser. Nothing is sent yet.
3. Submit (or 00:00): browser sends {attempt, answers by question id, seconds by question id} to submit_attempt.
4. SQL checks the attempt is the caller's and in time, compares with question_secrets, writes attempt_answers, and stores correct, wrong, skipped and score (+4 / -1 / 0).
5. Browser reads back the attempt rows (is_correct only, never the correct option) and shows the result.

B. Open a solution and run the tutor

1. POST /api/explain/open {attemptId, questionId}: the gate runs. Result: a session (access paid, free or staff), seconds left, first guiding question and shuffled tap choices. Or HTTP 402 paywall.
2. Each answer: POST /api/tutor/turn {questionId, messages, kind, hintLevel}. The server loads the question and secrets, builds the prompt, calls Claude (low effort, short reply), validates the JSON, runs the leak guard, updates counters, logs token use, and returns only {verdict, reply, step, established, choices, done}. Header X-Tutor-Mode says claude, scripted or limited.
3. Session finishes when done is true, the student taps Show me the answer (POST /api/tutor/finish skip), or the timer ends (finish timeout, checked against the server clock).
4. GET /api/explain/:questionId returns the answer and explanation, only for a finished session. POST /api/tutor/wrapup returns the Your thinking note. POST /api/video-url returns a signed video link when allowed.

C. Pay for a test

1. POST /api/payments/order {testId}: server reads the price from the database, creates a Razorpay order, stores a payments row (status created).
2. Browser opens Razorpay Checkout with that order. The student pays.
3. Razorpay calls POST /api/payments/webhook. The server verifies the signature, then SQL records the payment and inserts the unlock in one transaction.
4. Meanwhile the browser polls GET /api/payments/status/:orderId until it says paid, then reloads entitlements.
5. Refund: admin flags, refund is issued in Razorpay, webhook refund.processed marks Refunded and sets revoked_at on the unlock.

3.6 API reference

All routes need a signed-in user (Authorization: Bearer token) except the webhook (signature) and /health. Errors are JSON {"error": "code"}. A per-user limit of 60 requests a minute applies.

METHOD AND PATH	PURPOSE	NOTABLE RESPONSES
GET /health	Health check.	200 {ok: true}
POST /api/explain/open	Entitlement gate and tutor session start.	200 session; 402 paywall (with testId); 404 not your attempt or question
POST /api/tutor/turn	One tutor exchange.	200 {verdict, reply, step, established, choices, done}; 409 expired, finished or no_session
POST /api/tutor/finish	End the session (skip or timeout).	200; 409 too_early
POST /api/tutor/wrapup	Your thinking feedback.	200; 403 not_finished
GET /api/explain/:questionId	Answer and explanation.	200; 403 not_finished
POST /api/video-url	Short-lived signed video link.	200 {url, expiresIn} or {url: null}; 403 not_allowed
POST /api/payments/order	Create a Razorpay order.	200 {orderId, amount, keyId, ...}; 409 already_unlocked; 429; 503 not configured
POST /api/payments/webhook	Razorpay events.	200 {outcome}; 400 bad_signature
GET /api/payments/status/:orderId	Poll an order.	200 {status}
GET /api/me/export	Download my data.	200 JSON
DELETE /api/me	Delete my account (body {confirm: "DELETE"}).	200; 400; 409 last_admin

Direct database calls from the browser (under row-level security): reading tests, published questions, own attempts, unlocks, free uses, payments and revision items; and the SQL functions start_attempt, submit_attempt, complete_signup, plus the staff-only admin_* functions (upsert question, upsert test, get question, analytics, users, flag refund, grant unlock, set role).

3.7 Configuration

VARIABLE	WHERE	MEANING
VITE_SUPABASE_URL, VITE_SUPABASE_ANON_KEY	Frontend (public)	Leave empty for the offline demo.
VITE_API_URL	Frontend (public)	Address of the Node API.
VITE_SUPPORT_EMAIL, VITE_COMPANY_NAME	Frontend (public)	Shown in the policy and payment history.
DATABASE_URL	API (secret)	Postgres connection string. Use Supabase's Session pooler string.

VARIABLE	WHERE	MEANING
SUPABASE_URL, SUPABASE_SERVICE_ROLE_KEY	API (secret)	For token checks, signed URLs and account deletion.
ANTHROPIC_API_KEY, CLAUDE_MODEL, CLAUDE_EFFORT	API (secret)	Tutor model (default claude-haiku-5-5, low effort). Without the key the scripted tutor is used.
TUTOR_DAILY_LIMIT	API	Claude turns per student per 24 hours (default 60). After it the scripted tutor answers.
RAZORPAY_KEY_ID, RAZORPAY_KEY_SECRET, RAZORPAY_WEBHOOK_SECRET	API (secret)	Start with test keys. Webhook events: payment.captured, order.paid, payment.failed, refund.processed.
ALLOWED_ORIGINS, VIDEO_URL_TTL_SECONDS, PORT, PG_SSL	API	Allowed website addresses, signed-link lifetime (600), port, TLS switch.

3.8 Numbers builders should know

ITEM	VALUE
Free explanations	2 per student, total
Unlock price	Rs 100 per test (editable per test by staff)
Tutor timer / messages / hints	120 seconds / 5 student messages / 3 hints
Claude daily limit	60 turns per student per rolling 24 hours
Submit grace after time limit	5 minutes
Signed video link	10 minutes
Uploads	Video MP4 200 MB; diagram 5 MB (PNG, JPEG, WebP)
CSV import	500 rows, 1 MB
Ages	Minimum 13; guardian consent below 18
Order creation limit	10 per student per hour
Retention	Tutor sessions 30 days; AI usage 90 days; unsubmitted attempts 7 days; webhook event ids 60 days

3.9 Testing

LAYER	COMMAND	WHAT IT COVERS
Unit, database, API, integration	npm test	About 100 tests: row-level security and scoring on a real Postgres engine, free and paid rules including parallel requests, tutor rules and leak guard, payments and webhook, refunds, privacy and deletion, analytics, CSV, labels, languages.

LAYER	COMMAND	WHAT IT COVERS
Browser end to end	npm run test:e2e	Desktop and 390px phone: sign-in to unlocked solution (with a stubbed payment window and a signed webhook), minors, delete my data, language, option labels, layout without sideways scroll and 44px touch targets.
Run everything locally	npm run dev:stack, then npm run dev	Local database, sign-in stand-in, storage and API. Staff test numbers 9999999999 (admin) and 9888888888 (teacher), code 123456.

CI runs the same on every push (.github/workflows/ci.yml). **What the tests cannot prove:** behaviour against the real Supabase, Razorpay, Claude and hosting services. Do the test-mode run in docs/LAUNCH.md before taking real money.

3.10 Deployment

- Database: run supabase/setup-all.sql once in the Supabase SQL editor (or supabase db push), then seed.sql if wanted. Make the first admin with a one-line SQL update.
- API: Render (render.yaml) or any Node 22 host using the Dockerfile. Single instance first.
- Frontend: Vercel (vercel.json), normal build in dist/.
- Schedule public.purge_old_data() daily (pg_cron).
- Order: Supabase, API, frontend, then set ALLOWED_ORIGINS on the API to the frontend address, then Razorpay webhook.

3.11 Conventions

- Colours only from the design tokens in src/styles.css; both light and dark must work.
- Real buttons and labels, 44 pixel touch targets, visible focus. Correct and incorrect are never shown by colour alone: always an icon and text.
- Student-facing text goes through t(); English first.
- Admin numbers must be real. Sample or demo data is labelled as such.
- Add a database change as a new migration file (the existing ones may be edited only until the first real deployment). Regenerate setup-all.sql with npm run gen:setup-sql.
- The store keeps one set of action names for both the offline demo and the live backend; add new actions to both backends.

Part 4. Decisions, limits and next steps

4.1 Decisions made while building

- The result table hides the correct option until the explanation is opened, so the tutor cannot be bypassed.
- Questions have exactly four options. A fifth option would need a schema, scoring and tutor change.
- Scoring is fixed at +4 / -1 / 0; a Marks field was removed from the question form.
- Option label style is per question, not per test.
- The guardian consent is a recorded declaration, not a verified one.
- Hindi is a first draft; Meiteilon is intentionally empty until a translator fills it.

4.2 Known limits

- Refreshing the page during a test loses the answers (the attempt is not resumable).
- Video upload is a single request: a dropped connection restarts it.
- The burst limiter is per API instance; the daily Claude limit is in the database.
- Only the shell, sign-in and home screens are translated.
- Nothing has been run against real third-party services yet.

4.3 Next steps

- Go live with the checklist in docs/LAUNCH.md and run the test-mode payment, refund and video checks.
- Legal review of the privacy policy and consent method; decide whether to verify guardians by OTP.
- Native review of Hindi; commission Meiteilon; translate the remaining screens.
- Resumable video upload; resumable tests after a refresh.
- Physics and Chemistry: the schema already allows them; add content and enable the cards.

4.4 Glossary

TERM	MEANING
NEET (UG)	India's national entrance test for medical undergraduate courses.
Socratic tutor	A guide that teaches by asking short questions instead of giving the answer.
Entitlement	Whether a student may open an explanation: staff, paid test, a free slot already used, or a free slot available.
RLS (row-level security)	Database rules that decide which rows each user can read or change.
Webhook	A message Razorpay sends to our server to say a payment happened.
Signed URL	A web address for a private file that works only for a short time.
OTP	One-time password sent by SMS.
DPDP Act	India's Digital Personal Data Protection Act, 2023, which has special rules for children's data.